

Chapter 13: Object ACLs

1 The Concept: Access Control Lists (ACLs)

Technical Concept: Defining Object Permissions

In Active Directory, Access Control Lists (ACLs) are tables that define which security principals (trustees) can access a specific object and what type of access they have.

- **Access Control Entry (ACE):** Each entry in an ACL defines a specific trustee and their permissions.
- **Securable Objects:** Any named object in AD that contains a security descriptor, including user accounts, groups, and computers.
- **The Risk of Delegation:** Organizations often delegate rights like password resets or group membership modification to non-privileged users, creating potential escalation paths.
- **Common Misconfigurations:** Real-world environments frequently see "Everyone" having full rights over objects or domain users having local admin rights on all servers.

The Grand Hotel Analogy: The Room Access Log

Imagine every room and safe in the hotel has an **Access Log** (*ACL*) pinned to the door.

- **The Permission List:** The log lists everyone allowed to enter. For example, the **General Manager (Domain Admin)** is on every list.
- **The Error (Delegation):** The Manager allows the **Night Concierge (Bob)** to "Manage the Keys" for **Anni's Suite** (*Full Control over User Anni*).
- **The Sabotage:** Because Bob can manage keys, he decides to change the lock on Anni's door (*Password Reset*) and walk in pretending to be her.
- **The Result:** If Anni was a high-ranking executive, Bob now has all her privileges simply because he was given "management" rights over her room log.

2 Attack Execution: Step-by-Step

2.1 Step 1: Environment Enumeration

We use **SharpHound** to collect all ACL and relationship data from the domain to visualize them in **BloodHound**.

>_ Terminal: Windows PowerShell (as bob)

```
.\SharpHound.exe -c All
```

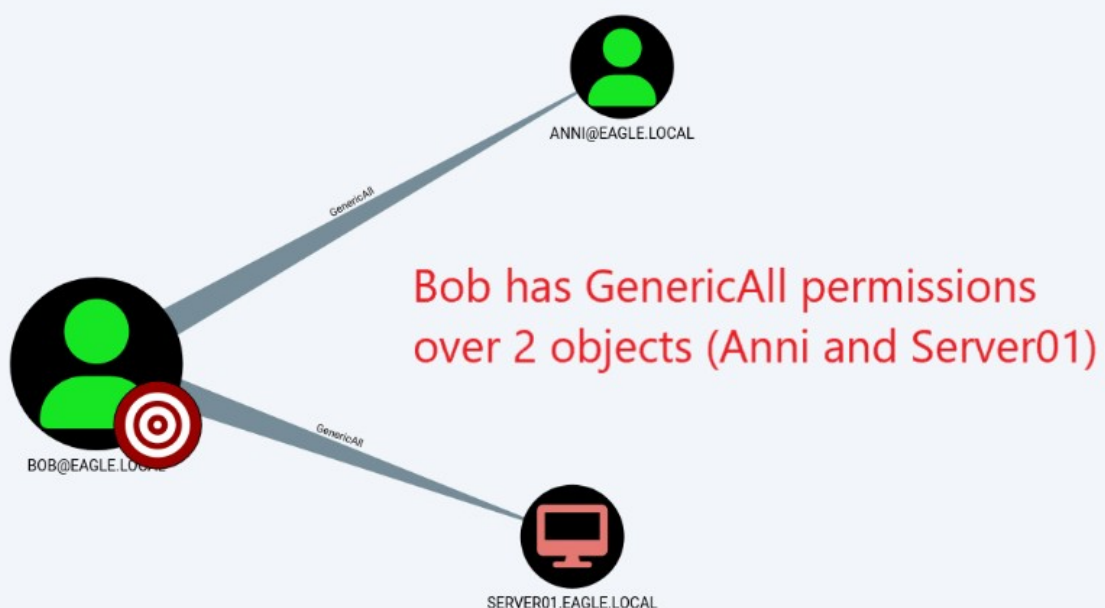
```
PS C:\Users\bob\Downloads> .\SharpHound.exe -c All
2022-12-19T14:16:39.1749601+01:00|INFORMATION|This version of SharpHound is compatible with the 4.2 Release of BloodHound
2022-12-19T14:16:39.3312221+01:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2022-12-19T14:16:39.3468314+01:00|INFORMATION|Initializing SharpHound at 14.16 on 19/12/2022
2022-12-19T14:16:39.5187113+01:00|INFORMATION|Flags: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2022-12-19T14:16:39.7530826+01:00|INFORMATION|Beginning LDAP search for eagle.local
2022-12-19T14:16:39.7999574+01:00|INFORMATION|Producer has finished, closing LDAP channel
2022-12-19T14:16:39.7999574+01:00|INFORMATION|LDAP channel closed, waiting for consumers
2022-12-19T14:17:09.8937530+01:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 36 MB RAM
2022-12-19T14:17:28.4874698+01:00|INFORMATION|Consumers finished, closing output channel
2022-12-19T14:17:28.5343302+01:00|INFORMATION|Output channel closed, waiting for output task to complete
Closing writers
2022-12-19T14:17:28.6124768+01:00|INFORMATION|Status: 114 objects finished (+114 2.375)/s -- Using 46 MB RAM
2022-12-19T14:17:28.6124768+01:00|INFORMATION|Enumeration finished in 00:00:48.8638030
2022-12-19T14:17:28.6905842+01:00|INFORMATION|Saving cache with stats: 74 ID to type mappings.
76 name to SID mappings.
1 machine sid mappings.
2 sid to domain mappings.
0 global catalog mappings.
2022-12-19T14:17:28.6905842+01:00|INFORMATION|SharpHound Enumeration Completed at 14.17 on 19/12/2022! Happy Graphing!
```

2.2 Step 2: Analyzing Potential Escalation Paths

After importing the data into BloodHound, we look for objects over which **Bob** has control.

Technical Concept: Exploitation Cases

- **Case 1: Rights over User Anni:** Bob can reset Anni's password or add a bogus SPN to her account to perform Kerberoasting.
- **Case 2: Rights over Server01:** Bob can obtain LAPS passwords from attributes or abuse Resource-Based Kerberos Delegation to compromise the machine.



3 Detection: Identifying Unauthorized Modifications

Technical Concept: Event IDs for Object Modification

While AD notifies us of changes, the events are often incomplete and do not show granular property modifications.

- **Event ID 4738:** Generated when a user account is changed (e.g., adding an SPN).
- **Event ID 4724:** Generated if an ACL abuse leads to a password reset.
- **Event ID 4742:** Generated when a computer object (like **Server01**) is modified.

4 Honeypots: Setting the ACL Trap

- **Setup:** Create a honeypot user that **everyone** can modify.
- **Monitoring:** Any **Event ID 4738** associated with this honeypot user is an immediate indicator of malicious activity.
- **Response:** Mature organizations may immediately disable the account performing the change and initiate forensics.

5 Prevention: Hardening Access Management

- **Continuous Assessment:** Regularly audit ACLs to detect improper delegations.
- **Automation:** Use automated processes for access management to reduce human error.
- **Least Privilege:** Only assign privileged access to administrative accounts, avoiding broad delegations to unprivileged users.